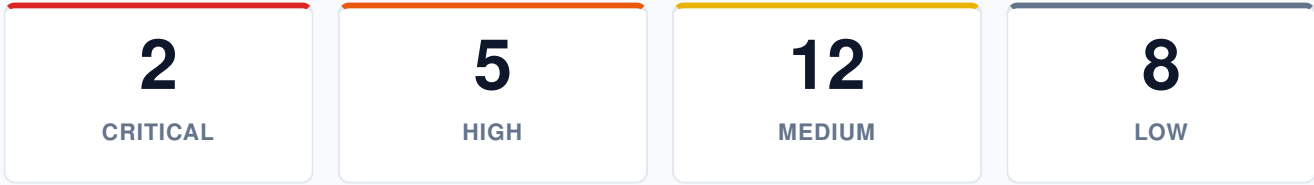


Security Vulnerability Report

Target: frontend-web-app (main) | Scanned on: September 4, 2026



Detailed Vulnerability Findings

SQL Injection (SQLi) in User Authentication				CRITICAL
Module / File:	auth-service@1.2.4	CVSS Score:	9.8	
Introduced By:	Commit a1b2c3d	Estimate to Fix:	~4 Hours	
DESCRIPTION				
The application constructs SQL queries by directly concatenating user-supplied input from the login form without parameterization. This allows an attacker to manipulate the SQL statement, potentially bypassing authentication, accessing unauthorized data, or modifying the database contents.				
RECOMMENDATION				
Refactor the database queries to use prepared statements or parameterized queries provided by the ORM. Ensure that all user inputs are strictly validated and escaped before processing. Upgrade to auth-service@1.3.0 or later which enforces strict parameterization natively.				
Cross-Site Scripting (XSS) - Reflected				HIGH
Module / File:	search-ui@2.0.1	CVSS Score:	7.5	
Introduced By:	Feature Branch PR #42	Estimate to Fix:	~1.5 Hours	
DESCRIPTION				
The search results page reflects the user's search query directly into the DOM without sufficient sanitization. An attacker can craft a malicious URL containing JavaScript payloads, leading to session hijacking or unauthorized actions performed on behalf of the victim when they click the link.				
RECOMMENDATION				
Implement context-aware output encoding. Use built-in framework protections (e.g., React's default escaping) or implement libraries like DOMPurify to sanitize untrusted input before rendering it in the browser DOM.				

Insecure Direct Object Reference (IDOR)

HIGH

Module / File: `invoice-api@3.1.0`

CVSS Score: **8.2**

Introduced By: **API V2 Migration**

Estimate to Fix: **~3 Hours**

DESCRIPTION

The endpoint `/api/v2/invoices/{id}` does not verify if the currently authenticated user has the necessary permissions to view the requested invoice. An attacker can enumerate sequential IDs to download invoices belonging to other customers.

RECOMMENDATION

Implement robust authorization checks at the controller level. Verify that the requested object belongs to the tenant or user context making the request. Alternatively, transition to non-sequential, unguessable identifiers like UUIDv4.

Prototype Pollution via Outdated Dependency

MEDIUM

Module / File: `lodash@4.17.15`

CVSS Score: **5.3**

Introduced By: `package.json`

Estimate to Fix: **~30 Minutes**

DESCRIPTION

The application depends on a version of lodash that is vulnerable to Prototype Pollution (CVE-2020-8203). This could allow an attacker to modify the prototype of base object properties, potentially leading to denial of service or remote code execution in specific edge cases.

RECOMMENDATION

Upgrade `lodash` to version `4.17.21` or later. Ensure your package lockfile is updated and verify that the application test suite passes post-upgrade. Run an `npm audit fix` to ensure transitive dependencies are also updated.

Server Information Leakage

LOW

Module / File: `nginx.conf`

CVSS Score: **3.1**

Introduced By: **Initial Setup**

Estimate to Fix: **~15 Minutes**

DESCRIPTION

The web server exposes its exact version via the `Server` HTTP response header (e.g., `Server: nginx/1.18.0`). This provides attackers with reconnaissance data that can be used to target specific known exploits for that version.

RECOMMENDATION

Configure the web server to disable version exposure. For Nginx, set `server_tokens off;` in the `http` block of the configuration file and reload the service.